PLAYBOOK DE RESPUESTA

PB-04 | Inicio de sesión VPN anómalo

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar acceso de administración por VPN desde país inusual al bastión o recursos de pago.

02. Disparador, fuente y umbral

Eventos del NGFW/VPN y Wazuh. Umbral propuesto: primer acceso administrativo desde país fuera de patrón, dos países en <60 min o IP nueva en horario inusual.

03. Severidad inicial y promoción

Alta si cuenta privilegiada/acceso remoto sin explicación; Crítica si se siguen consultas privilegiadas o cambios de claves; Media para viaje autorizado corroborado.

04. Triage: validación paso a paso

1. Verificar inicio exitoso y contexto del túnel VPN sitio a sitio frente a VPN de acceso remoto.
2. Comprobar usuario, MFA, IP pública, ASN y país estimado; geolocalización no es prueba concluyente.
3. Comparar historial de 30 días y turnos de guardia del usuario.
4. Contactar al titular por canal independiente, no por sesión sospechosa.
5. Revisar cambios de privilegio, transferencia de información y accesos a API/BD posteriores.

05. Contención autorizada a N1

- Solicitar cierre de sesión y rotación de credenciales a TI bajo procedimiento.
- Para cuenta no privilegiada, solicitar bloqueo preventivo ante falta de reconocimiento.

06. Acciones no autorizadas a N1

- No deshabilitar cuentas administrativas por cuenta propia.
- No bloquear sin análisis el túnel sitio a sitio de producción.

07. Evidencia mínima preservada

- VPN: hora, usuario, IP, MFA, país aproximado, gateway y sesión.
- Respuesta del titular y acciones inmediatamente posteriores.

08. Escalamiento obligatorio a N2

Cuenta administrativa, acceso no reconocido, múltiples accesos o acciones sensibles sobre BD/API.

09. Criterios de cierre técnico

Confirmación independiente de viaje o guardia; conservar aprobación y recomendaciones MFA.

10. Mejora continua

Líneas base geográficas y detección de viaje imposible ajustadas por VPN corporativa.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-04 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.